

5 Señales de que tu Infraestructura Linux ha sido Vulnerada

Guía de Análisis Forense para Detectar al
'Intruso Silencioso'

El intruso silencioso: El enemigo que no quiere ser visto

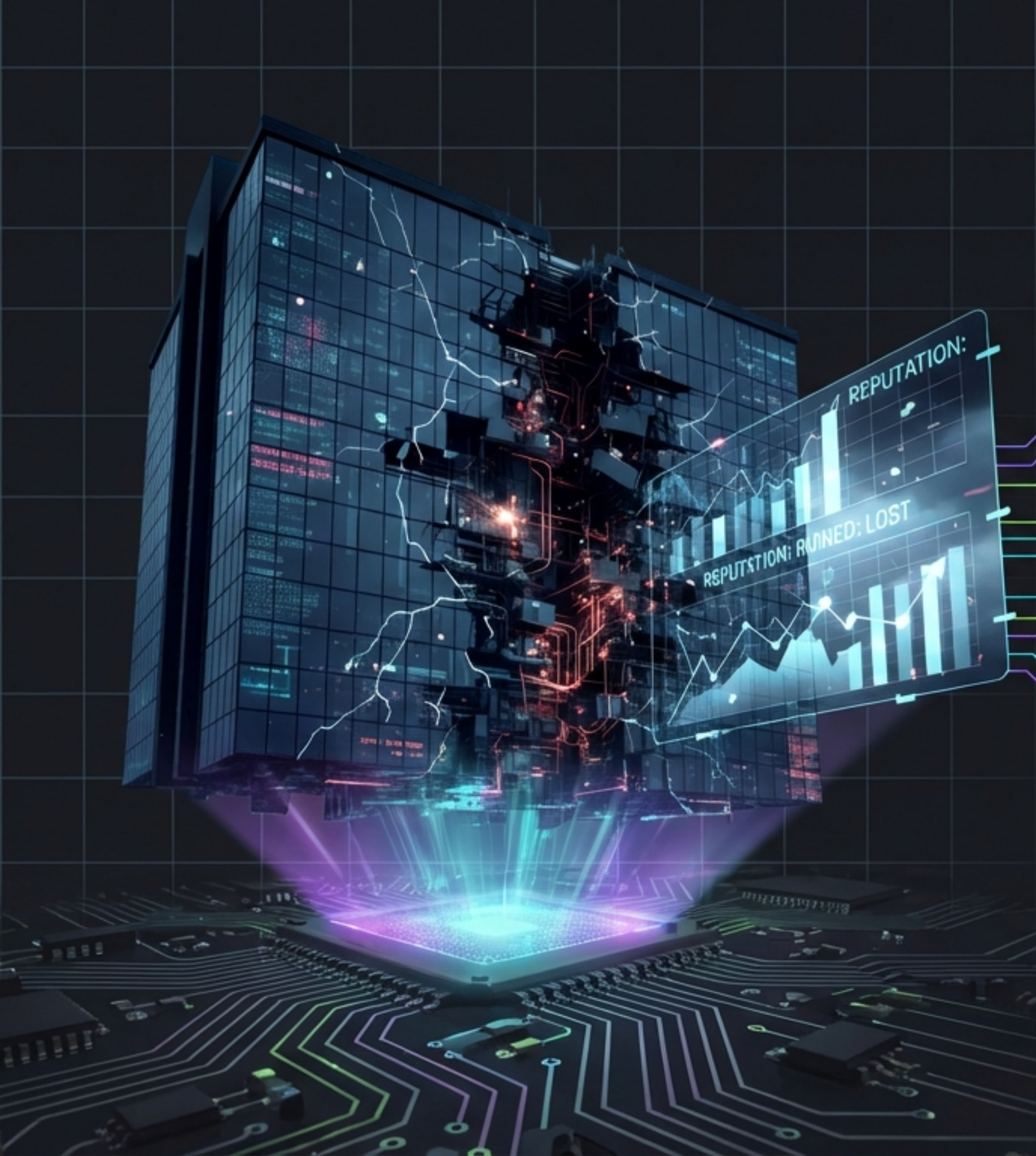
/ «Lo que no se ve no existe» /
/ – George Berkeley

La Psique del Atacante: A diferencia de los ataques clásicos que buscaban destruir o desfigurar, el atacante moderno prioriza la persistencia.

El Objetivo: Pasar desapercibido para robar datos continuamente, usar capacidad de cómputo (Criptominería/Botnets) o planificar movimientos laterales.

Modus Operandi: Evitan levantar sospechas de administradores y sistemas de monitoreo. No borran archivos visibles ni tiran el servicio.





El costo de la invisibilidad

// El peligro real no es el impacto
// inmediato, sino el daño acumulativo
// mientras el servidor funciona con
// normalidad.

1. > **Robo de Información:** Filtración progresiva de credenciales, claves privadas y bases de datos.
2. > **Uso Indebido:** Minería de criptomonedas a baja intensidad.
3. > **Integración con Botnets:** Participación en ataques DDoS y Spam.
4. > **Plataforma de Salto (Pivoting):** Usar la reputación de tu servidor para atacar sistemas internos o externos.

Señal 1: La Carga Fantasma

Procesos Zombi y CPU

El Síntoma

Un servidor estable comienza a mostrar lentitud o una carga de CPU ligeramente superior sin cambios operativos legítimos.

El Sospechoso

Mineros de Cripto: Procesos de bajo perfil que consumen un constante 5-20% de CPU.

Camuflaje: Nombres que imitan servicios reales (kworker, systemd-helper) pero ejecutándose desde rutas inusuales (/tmp, /home, /dev/shm).

```
#top - 22:45:48 up 15 min, 2 users, load average: 0,03, 0,10, 0,16
Tasks: 301 total, 1 running, 250 sleeping, 0 stopped, 0 zombie
%Cpu(s): 0,1 us, 0,0 sy, 0,0 ni, 99,9 id, 0,0 usd, 0,0 hi, 0,0 si, 0,0 st
```

PID	USER	PR	NI	VIRT	RES	SHR	S	%CPU	%MEM	TIME+	COMMAND
921	root	20	0	560348	17468	14008	S	0,3	0,1	0:01.10	NetworkManager
1080	mysql	20	0	1424012	180692	15548	S	0,3	1,1	0:00.95	mysqld
1106	gdm	20	0	3489264	166816	110924	S	0,3	1,0	0:02.79	gnome-shell
2398	root	20	0	469744	104324	69688	S	0,3	0,6	0:06.37	Xorg
3366	root	20	0	577804	34964	18340	S	0,3	0,2	0:00.21	fwupd
1	root	20	0	234384	9892	6580	S	0,0	0,1	0:02.85	systemd
3	root	0	-20	0	0	0	I	0,0	0,0	0:00.00	rcu_gp
4	root	0	-20	0	0	0	I	0,0	0,0	0:00.00	rcu_par_gp
6	root	0	-20	0	0	0	I	0,0	0,0	0:00.00	kworker70:0H-kb
8	root	0	-20	0	0	0	I	0,0	0,0	0:00.00	mm_percpu_wq
9	root	20	0	0	0	0	S	0,0	0,0	0:00.03	ksftirqd70

Análisis Forense: Cazando el Proceso

Comando Principal:

```
$ ps auxf --sort=-%cpu |  
head -10
```

Explicación: Ordena procesos por consumo de CPU y muestra jerarquía en árbol.

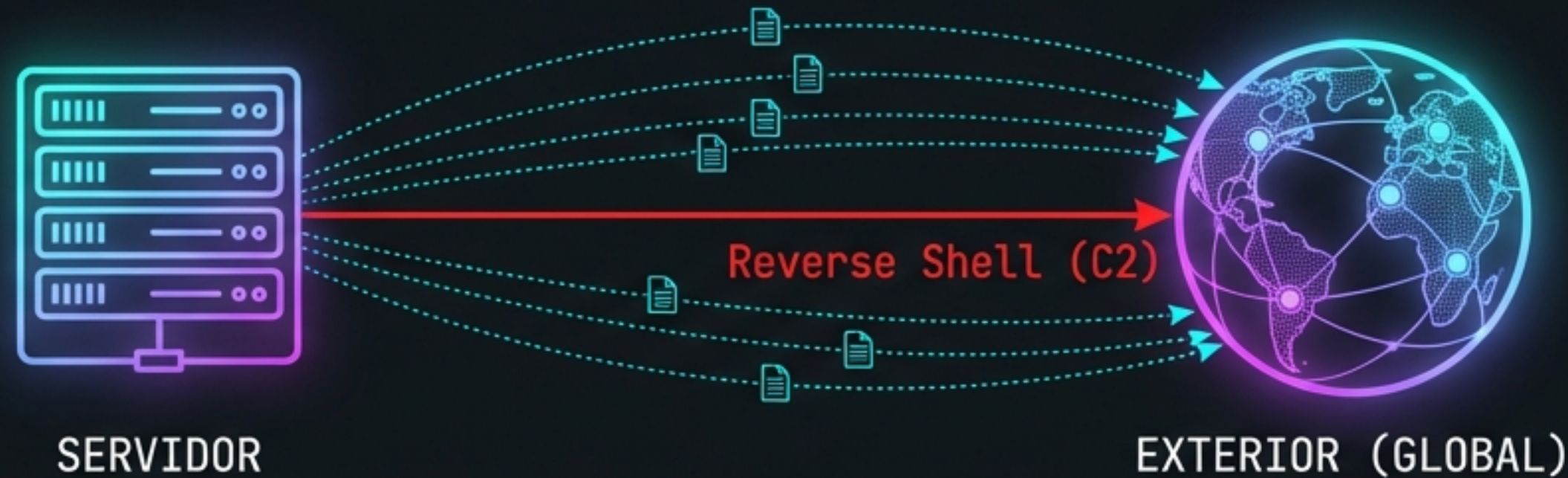
Indicadores de Compromiso:

1. Nombres aleatorios (ej. xmr-stak).
2. Procesos legítimos ubicados fuera de /bin o /usr/sbin.
3. Ejecución desde directorios temporales (/tmp, /var/tmp).

Terminal Window

```
#ps auxf --sort=-%cpu | head -10  
USER      PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND  
root         2  0.0  0.0      0     0 ?        S    22:30   0:00 [kthreadd]  
root    1146  0.4  0.0      0     0 ?        S    22:30   0:18 \_ [irq/129-nvidia]  
root         3  0.0  0.0      0     0 ?        I<   22:30   0:00 \_ [rcu_gp]  
root         4  0.0  0.0      0     0 ?        I<   22:30   0:00 \_ [rcu_par_gp]  
root         6  0.0  0.0      0     0 ?        I<   22:30   0:00 \_ [kworker/0:0H-kb]  
root         8  0.0  0.0      0     0 ?        I<   22:30   0:00 \_ [mm_percpu_wq]  
root         9  0.0  0.0      0     0 ?        S    22:30   0:00 \_ [ksoftirqd/0]  
root        10  0.0  0.0      0     0 ?        I    22:30   0:00 \_ [rcu_sched]  
root        11  0.0  0.0      0     0 ?        S    22:30   0:00 \_ [migration/0]
```


Señal 2: Conexiones de Red Inusuales



El Síntoma:

El servidor "habla demasiado" con el exterior. Tráfico saliente constante incluso con baja carga de trabajo.

La Amenaza:

- **Reverse Shell:** El atacante elude el firewall iniciando la conexión DESDE el servidor hacia un C2 (Comando y Control) externo.
- **Exfiltración:** Envío de datos o resultados de minería a IPs desconocidas.

Análisis Forense: Auditando el Tráfico

Terminal Window

```
# netstat -antup
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 127.0.0.1:631            0.0.0.0:*               LISTEN      1166/cupsd
tcp        0      0 0.0.0.0:22               0.0.0.0:*               LISTEN      1/init
tcp        0      0 127.0.0.53:53            0.0.0.0:*               LISTEN      547/systemd-resolve
tcp        0      0 127.0.0.54:53            0.0.0.0:*               LISTEN      547/systemd-resolve
tcp        0      64 192.168.43.128:22        192.168.43.1:52973     ESTABLISHED 5475/sshd: roberto
tcp6       0      0 :::631                   :::*                    LISTEN      1166/cupsd
tcp6       0      0 :::22                    :::*                    LISTEN      1/init
udp        0      0 127.0.0.54:53            0.0.0.0:*               547/systemd-resolve
udp        0      0 127.0.0.53:53            0.0.0.0:*               547/systemd-resolve
udp        0      0 192.168.43.128:68        192.168.43.254:67     ESTABLISHED 933/NetworkManager
udp        0      0 0.0.0.0:50403            0.0.0.0:*               809/avahi-daemon: r
udp        0      0 0.0.0.0:5353             0.0.0.0:*               809/avahi-daemon: r
udp6       0      0 :::55198                 :::*                    809/avahi-daemon: r
udp6       0      0 :::5353                  :::*                    809/avahi-daemon: r
```

Proceso sshd o
NetworkManager
iniciando conexión.

Conexión activa
hacia IP externa.

Proceso sshd o
NetworkManager
iniciando conexión.

Comando: `$ netstat -antup` o `$ ss -tupn`

Buscar: Estado ESTABLISHED hacia IPs de países no operativos o puertos sospechosos (4444, 6667).

Señal 3: Usuarios y Cuentas Ocultas

El Síntoma:

Aparición de usuarios que no fueron creados por IT o actividad en cuentas que deberían estar inactivas.

La Táctica:

1. **Camuflaje de Nombres:** Creación de usuarios como 'ftpservice', 'sysadm' o 'backup' para pasar desapercibidos.
2. **Privilegios Falsos:** Asignación de UIDs bajos (<1000) para simular ser cuentas del sistema.
3. **Llaves SSH:** Inyección de claves públicas en ~/.ssh/authorized_keys para acceso persistente sin contraseña.



Análisis Forense: Verificando la Lista de Acceso

```
#lastlog | grep -v 'Never logged in'
Username      Port      From      Latest
roberto       pts/1     192.168.0.3  dom ene 11 18:35:47 -0400 2026
# █
```

\$ lastlog | grep -v 'Never logged in' (Muestra quién inició sesión realmente)

```
#cat /etc/passwd | grep sh$
root:x:0:0:root:/root:/bin/bash
juan:x:1000:1000:juan perez,,,:/home/reddy:/bin/bash
roberto:x:1001:1001:Roberto Mercado,,,:/home/roberto:/bin/bash
postgres:x:124:129:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
# █
```

\$ cat /etc/passwd | grep sh\$ (Filtra usuarios con acceso a terminal)

```
$ getent group sudo
sudo:x:27:roberto,juan
# █
```

\$ getent group sudo (Revisa quién tiene privilegios de superusuario)

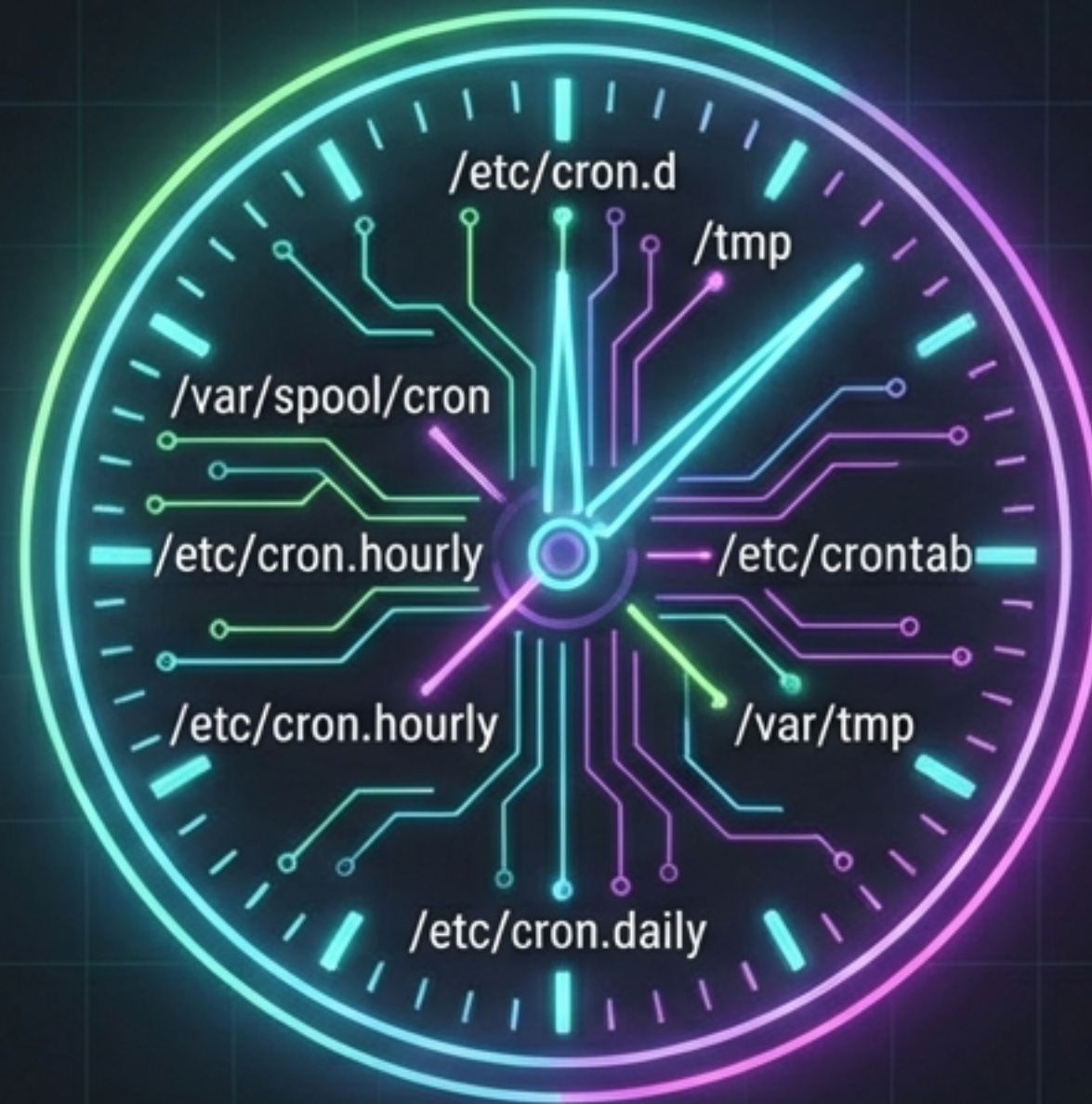
Tip de Experto: Revisar manualmente ~/.ssh/authorized_keys buscando llaves públicas desconocidas.

Señal 4: Tareas Programadas Maliciosas

La Bomba de Tiempo

El Síntoma:

El malware reaparece tras ser eliminado, o el rendimiento cae en intervalos regulares (cada hora/día).



El Mecanismo:

Cron Jobs

Ciclo de Ataque:

Descarga y ejecución automática de scripts (Ransomware, Mineros, Backdoors) escondidos entre tareas legítimas de mantenimiento.

Análisis Forense: Auditoría de Cron

```
for user in $(cut -f1 -d: /etc/passwd); do
    echo "Checking user: $user"
    crontab -u $user -l
done
```

Comando Básico: \$ crontab -l (Solo revisa el usuario actual)

Directorios Críticos: \$ ls -la /etc/cron.d/

Alerta: Prestar atención a usuarios del sistema como 'www-data' o 'lp' ejecutando scripts inusuales.

Señal 5: Logs que Desaparecen

```
# ls -lh /var/log/  
-rw-r----- 1 syslog adm 19K ene 17 18:17 /var/log/auth.log  
-rw-r----- 1 syslog adm  0B ene 17 18:17 /var/log/auth.log
```

El Síntoma

Huecos de tiempo en los registros (ej. salto de 22:25 a 23:55) o archivos de log vacíos en un servidor activo.

“La evidencia más incriminatoria es la ausencia de evidencia. Si auth.log o secure tienen 0 bytes, alguien ejecutó una limpieza.”

Análisis Forense: Detectando la Limpieza

Historial de Comandos

```
$ history
```

Si está vacío o muy corto, es una señal roja.

```
# history
1 cd /root/
2 ls
3 cd ..
4 ls
5 cd /home/
```

Accesos Binarios

```
$ utmpdump /var/log/wtmp
```

Recupera intentos de acceso de archivos binarios.

Modificaciones Recientes

```
$ find /var/log -type f -mtime -1
```

Muestra logs modificados en las últimas 24 horas.

```
/var/log/vmtoolsd.log
/var/log/lastlog
/var/log/Xorg.0.log
/var/log/auth.log
/var/log/mysql/error.log
/var/log/mysql/error.log.1.gz
/var/log/boot.log
/var/log/postgresql/postgresql-10-main
/var/log/wtmp
/var/log/journal/e53e2e697aaa4f718375f
```


La Regla de Oro del Logging

No puedes proteger logs que están almacenados únicamente en la máquina comprometida.



Estrategia: **Logging Centralizado**. Si un atacante elimina el log local, la evidencia ya está a salvo en otro servidor fuera de su alcance.

Resumen de Comandos Forenses

Objetivo	Comando Clave
Procesos	<code>\$ ps auxf --sort=-%cpu head -10</code>
Red	<code>\$ netstat -antup</code>
Usuarios	<code>\$ lastlog grep -v 'Never logged in'</code>
Persistencia	<code>\$ crontab -l</code>
Logs	<code>\$ find /var/log -type f -mtime -1</code>

"La vigilancia constante es la única defensa contra el intruso silencioso."